

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Week 3 Lab Assignment: Risk Management Fundamentals

Full Name	Adebukola Olanipekun
Registration Number	C11/26/CGRCE/17603
Email Address	bukolufemi@gmail.com
Cohort / Batch	11
Date Submitted	7th August, 2026

Part 1: Risk Management Concepts

1. Define the following terms:

Risk is the possibility that an event or condition could negatively affect an organization's ability to achieve its goals. In cybersecurity, risk normally exists when a threat can take advantage of a weakness and cause harm.

A **threat** is anything that could cause harm to an information system, data, or business operation. Threats may come from cybercriminals, malicious insiders, natural disasters, human mistakes, or system failures.

A **vulnerability** is a weakness that a threat can exploit. Examples include weak passwords, unpatched software, excessive user permissions, poor encryption, or employees who have not received security training.

Impact refers to the consequence of a risk event if it occurs. The impact may include financial loss, operational disruption, regulatory penalties, damaged reputation, loss of customer trust, or exposure of confidential information.

Likelihood is the probability that a specific threat will exploit a vulnerability and cause a risk event. It is often rated from low to high or on a numerical scale.

These concepts are closely connected. A threat exploits a vulnerability, which creates the possibility of a risk event. The seriousness of that risk depends on both the likelihood of it happening and the impact it would have on the organization. For example, a phishing attack is a threat, employees who cannot recognize phishing messages are the vulnerability, and the risk is that attackers may obtain access to customer data. The risk becomes more serious if the likelihood is high and the potential impact is severe.

2. Qualitative and Quantitative Risk Assessments

A **qualitative risk assessment** uses descriptive ratings such as low, medium, high, or critical to evaluate likelihood and impact. It usually relies on the judgment of subject-matter experts, past incidents, interviews, workshops, and risk matrices.

A **quantitative risk assessment** uses numerical values to estimate risk. It may calculate expected financial loss, annual loss expectancy, probability of an event, recovery costs, downtime costs, or regulatory penalties.

Assessment Method	Advantages	Disadvantages	Best Use Cases
Qualitative	Faster to complete, easier for employees and management to understand, useful when reliable financial data is unavailable	Can be subjective, depends heavily on expert judgment, and may produce different ratings from different assessors	Early-stage assessments, small organizations, fast-moving projects, and situations where data is limited
Quantitative	Produces measurable financial estimates, supports budget decisions, helps compare risks objectively, and is useful for cost-benefit analysis	Requires reliable data, takes more time, may involve complex calculations, and estimates can still be inaccurate	Large investments, insurance decisions, major cloud migrations, business continuity planning, and risks with measurable financial consequences

I would recommend using a qualitative approach when an organization needs a quick and practical assessment or does not have enough accurate data to estimate financial losses. I would recommend a quantitative approach when management needs to make a major investment decision, compare the cost

of controls, or understand the possible financial exposure of a serious risk. In many cases, using both approaches together is the most effective option.

Part 2: Risk Identification Exercise

The risks apply to a medium-sized financial services company migrating a CRM system containing customer financial information and personally identifiable information (PII) from an on-premises environment to a cloud-based service.

Risk Statement	Risk Category	Threat Source / Actor	Vulnerability Being Exploited
Customer financial information or PII could be exposed because the cloud CRM environment is incorrectly configured.	Technical / Compliance	External attackers, cloud configuration errors, or administrators	Misconfigured storage, databases, network rules, or access settings
Unauthorized users could gain access to CRM records through compromised employee accounts.	Technical / Security	Phishing attackers, credential thieves, or malicious insiders	Weak passwords, lack of multi-factor authentication, or poor access management
Customer data could be lost or corrupted during migration from the on-premises system to the cloud platform.	Operational / Technical	Human error, migration tool failure, or system malfunction	Incomplete backups, poor validation procedures, or untested migration scripts
The organization could violate privacy regulations by transferring or storing PII in an unauthorized region.	Compliance / Legal	Internal project team, cloud provider, or third-party vendor	Poor data classification, weak vendor oversight, or lack of data residency controls

Risk Statement	Risk Category	Threat Source / Actor	Vulnerability Being Exploited
A cloud service outage could interrupt employees' access to customer information and affect customer service.	Operational / Availability	Cloud provider outage, network disruption, or denial-of-service attack	Lack of redundancy, weak disaster recovery planning, or single-provider dependency
Sensitive information could be exposed because former employees retain access to the CRM system.	Security / Operational	Former employees or malicious insiders	Delayed account deactivation and poor identity lifecycle management
The company could face regulatory penalties if it does not maintain adequate audit logs and records of customer-data access.	Compliance / Reputational	Regulators, auditors, or internal users	Inadequate logging, short log-retention periods, or lack of monitoring
A third-party cloud vendor could fail to meet security or privacy obligations, exposing the company to legal and reputational risk.	Third-Party / Compliance	Cloud service provider or subcontractors	Weak contract terms, missing data processing agreement, or insufficient vendor due diligence
Employees could accidentally share CRM data with unauthorized recipients through insecure exports, email, or file-sharing tools.	Human / Operational	Employees, contractors, or accidental insiders	Lack of data loss prevention controls, poor training, or excessive download permissions

Risk Statement	Risk Category	Threat Source / Actor	Vulnerability Being Exploited
The migration project could exceed its budget or timeline, delaying operations and increasing business costs.	Project / Financial	Project team, consultants, or vendor delays	Unrealistic planning, unclear responsibilities, and poor change management
Attackers could exploit unpatched integrations or application programming interfaces (APIs) connected to the cloud CRM.	Technical / Security	Cybercriminals or automated scanning tools	Outdated software, insecure API keys, and weak vulnerability management
The company could suffer reputational damage if customers learn that their financial information was mishandled during the migration.	Reputational	Media, customers, regulators, or attackers	Weak incident communication plan and inadequate security controls

Part 3: Risk Assessment Matrix

The five risks below are the most significant because they could directly affect sensitive financial data, regulatory compliance, and the company's reputation.

Risk	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Level
Exposure of customer financial information or PII due to cloud misconfiguration	4	5	20	Critical
Unauthorized access through	4	5	20	Critical

Risk	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Level
compromised employee credentials				
Regulatory noncompliance caused by improper data residency or privacy controls	3	5	15	High
Customer data loss or corruption during migration	3	5	15	High
Cloud service outage affecting CRM availability	3	4	12	High

The cloud misconfiguration and compromised-credentials risks are rated critical because both can lead directly to a serious data breach involving sensitive customer financial information. The regulatory compliance and data-loss risks are rated high because they could result in major financial, legal, and operational consequences. The cloud outage risk is also high because it could affect customer service, employee productivity, and business continuity.

Part 4: Risk Mitigation Strategies

Risk 1

Item	Response
Risk Statement	Customer financial information or PII could be exposed because the cloud CRM environment is incorrectly configured.
Mitigation Approach	Mitigate

Item	Response
Specific Controls / Actions	Use secure cloud configuration baselines; apply the principle of least privilege; encrypt data at rest and in transit; require configuration reviews before deployment; use cloud security posture management tools; conduct regular vulnerability scans; perform penetration testing; and continuously monitor security logs and configuration changes.
Responsible Stakeholders	Chief Information Security Officer (CISO), Cloud Security Team, IT Operations Team, CRM Administrator, Compliance Officer, and Cloud Service Provider.
Effectiveness Metrics	Percentage of cloud configurations reviewed before deployment; number of critical misconfigurations identified each month; average time to remediate configuration findings; percentage of sensitive data encrypted; and number of unauthorized access attempts blocked.
Residual Risk	Medium

The organization cannot remove all cloud-related risk, but these controls reduce the chance that an incorrect setting will expose customer information. Continuous monitoring is especially important because cloud environments can change quickly.

Risk 2

Item	Response
Risk Statement	Unauthorized users could gain access to CRM records through compromised employee accounts.
Mitigation Approach	Mitigate
Specific Controls / Actions	Require multi-factor authentication for all CRM users; enforce strong password requirements; use single sign-on and centralized identity

Item	Response
	management; conduct phishing-awareness training; monitor unusual logins; apply role-based access control; disable inactive accounts; and review user access at least quarterly.
Responsible Stakeholders	IT Security Manager, Identity and Access Management Team, Human Resources, Department Managers, CRM Administrator, and Compliance Officer.
Effectiveness Metrics	MFA enrollment rate; percentage of accounts reviewed quarterly; phishing-simulation failure rate; number of suspicious login attempts detected; number of inactive accounts removed; and average time to disable accounts after employee separation.
Residual Risk	Medium

This risk remains at a medium level because phishing and credential theft can still occur. However, multi-factor authentication, access reviews, and user awareness training significantly reduce the likelihood that stolen passwords will result in unauthorized CRM access.

Risk 3

Item	Response
Risk Statement	The organization could violate privacy regulations by transferring or storing PII in an unauthorized region or without proper privacy controls.
Mitigation Approach	Mitigate and transfer
Specific Controls / Actions	Classify customer data before migration; confirm where the cloud provider stores and processes data; select approved cloud regions; complete a data protection impact assessment; establish a data processing agreement with the provider; review contractual privacy obligations; involve

Item	Response
	Legal and Compliance in the migration process; and conduct periodic privacy compliance audits.
Responsible Stakeholders	Compliance Officer, Data Protection Officer, Legal Counsel, Cloud Migration Project Manager, Procurement Team, CRM Owner, and Cloud Service Provider.
Effectiveness Metrics	Percentage of regulated data classified before migration; percentage of vendors with signed data processing agreements; number of privacy findings identified during audits; number of unauthorized data transfers detected; and completion rate for privacy impact assessments.
Residual Risk	Low to Medium

This approach combines mitigation and transfer. The organization reduces its own exposure through strong internal controls while using contractual commitments and data processing agreements to make sure the cloud provider shares responsibility for protecting the data.